

252-0463-00L Security Engineering

Semester	Autumn Semester 2025
Lecturers	D. Basin, S. Krstic
Periodicity	yearly recurring course
Language of instruction	English

◀ Tabs

Courses

Number	Title	Hours	Lecturers
252-0463-00 V	Security Engineering	2 hrs Wed 10:15-12:00 CAB G 51 »	D. Basin, S. Krstic
252-0463-00 U	Security Engineering Lab sessions every Friday in CHN D46 from 10-12	2 hrs Wed 14:15-16:00 CAB G 51 » Fri 10:15-12:00 CHN D 46 »	D. Basin, S. Krstic
252-0463-00 A	Security Engineering	2 hrs	D. Basin, S. Krstic

Catalogue data

Abstract	Subject of the class are engineering techniques for developing secure systems. We examine concepts, methods and tools, applied within the different activities of the SW development process to improve security of the system. Topics: security requirements&risk analysis, system modeling&model-based development methods, implementation-level security, and evaluation criteria for secure systems
Learning objective	Security engineering is an evolving discipline that unifies two important areas: software engineering and security. Software Engineering addresses the development and application of methods for systematically developing, operating, and maintaining, complex, high-quality software. Security, on the other hand, is concerned with assuring and verifying properties of a system that relate to confidentiality, integrity, and availability of data. The goal of this class is to survey engineering techniques for developing secure systems. We will examine concepts, methods, and tools that can be applied within the different activities of the software development process, in order to improve the security of the resulting systems. Topics covered include * security requirements & risk analysis, * system modeling and model-based development methods, * implementation-level security, and * evaluation criteria for the development of secure systems

Content

Security engineering is an evolving discipline that unifies two important areas: software engineering and security. Software Engineering addresses the development and application of methods for systematically developing, operating, and maintaining, complex, high-quality software.

Security, on the other hand, is concerned with assuring and verifying properties of a system that relate to confidentiality, integrity, and availability of data.

The goal of this class is to survey engineering techniques for developing secure systems. We will examine concepts, methods, and tools that can be applied within the different activities of the software development process, in order to improve the security of the resulting systems.

Topics covered include

- * security requirements & risk analysis,
- * system modeling and model-based development methods,
- * implementation-level security, and
- * evaluation criteria for the development of secure systems

Modules taught:

1. Introduction
 - Introduction of Infsec group and speakers
 - Security meets SW engineering: an introduction
 - The activities of SW engineering, and where security fits in
 - Overview of this class
2. Requirements Engineering: Security Requirements and some Analysis
 - Overview: functional and non-functional requirements
 - Use cases, misuse cases, sequence diagrams
 - Safety and security
3. Modeling in the design activities
 - Structure, behavior, and data flow
 - Class diagrams, statecharts
4. Model-driven security for access control (Part I)
 - SecureUML as a language for access control
 - Combining Design Modeling Languages with SecureUML
 - Semantics, i.e., what does it all mean,
 - Generation
 - Examples and experience
5. Model-driven security (Part II)
 - Continuation of above topics
6. Security patterns (design and implementation)
7. Implementation-level security
 - Buffer overflows
 - Input checking
 - Injection attacks
8. Code scanning
 - Static code analysis basics
 - Theoretical and practical challenges
 - Analysis algorithms
 - Common bug pattern search and specification
 - Dataflow analysis
9. Testing
 - Overview and basics
 - Model-based testing
 - Testing security properties
10. Risk analysis and management
 - "Risk": assets, threats, vulnerabilities, risk
 - Risk assessment: quantitative and qualitative
 - Safeguards
 - Generic risk analysis procedure
 - The OCTAVE approach
 - Example of qualitative risk assessment
11. Threat modeling
 - Overview
 - Safety engineering basics: FMEA and FTA
 - Security impact analysis in the design phase
 - Modeling security threats: attack trees
 - Examples and experience
12. Evaluation criteria
 - NIST special papers
 - ISO/IEC 27000
 - Common criteria
 - BSI baseline protection

13. Guest lecture
- TBA

Literature

- Ross Anderson: Security Engineering, Wiley, 2001.
- Matt Bishop: Computer Security, Pearson Education, 2003.
- Ian Sommerville: Software Engineering, 6th ed., Addison-Wesley, 2001.
- John Viega, Gary McGraw: Building Secure Software, Addison-Wesley, 2002.
- Further relevant books and journal/conference articles will be announced in the lecture.

Prerequisites / Notice Prerequisite: Class on Information Security

Performance assessment

Performance assessment information (valid until the course unit is held again)	
► Performance assessment as a semester course	
ECTS credits	7 credits
Examiners	D. Basin , S. Krstic
Type	end-of-semester examination
Language of examination	English
Repetition	The performance assessment is only offered at the end after the course unit. Repetition only possible after re-enrolling.
Mode of examination	written 120 minutes
Additional information on mode of examination	20% of your grade is determined by mandatory project work and 80% is determined by a written end-of-semester exam (120 min). Not participating in the project work incurs grade 1 for the project work.
Written aids	None

Learning materials

Main link	Information
Learning environment	Information
Only public learning materials are listed.	

Groups

No information on groups available.

Restrictions

There are no additional restrictions for the registration.

Offered in

Programme	Section	Type	
CAS in Computer Science	Focus Courses and Electives	W	
Cyber Security Master	Core Courses	W	
DAS in Cyber Security	Elective Courses	W	
Computer Science Master	Core Courses	W	

Computer Science Master	Minor in Information Security	W	
MAS in Cyber Security	Elective courses	W	